

Humans as Attack Vectors Write-up

Understand why and how people are targeted in cyber attacks and how the SOC helps defend them.

Task 1 Introduction

The Security Operations Center (SOC) might sound technical and impressive, but what does it really protect us from? In this room, you will dive into the methods of modern attackers and explore how they target the weakest cyber security element - humans.

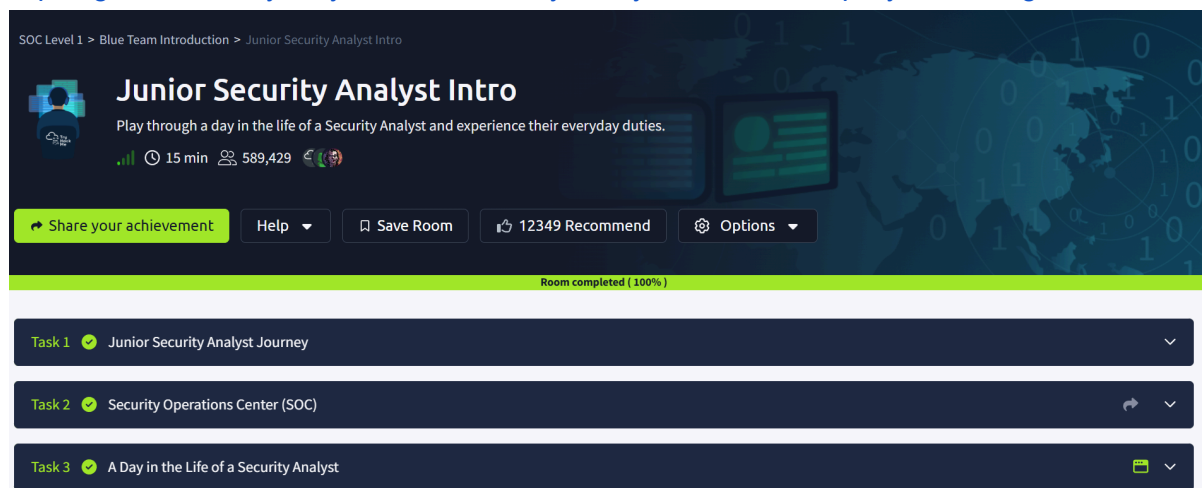
Learning Objectives

- Learn the role of the human element in cyber security
- Understand the SOC role in detecting and mitigating attacks
- Practice the acquired knowledge in two realistic scenarios

Prerequisites

Complete the Junior Security Analyst room: <https://tryhackme.com/room/jrsecanalystintrouxo>
Here is the Write-up to this room:

<https://github.com/Nyabayo/Junior-Security-Analyst-Intro-Write-up-tryhackme-.git>



Task 2 The Human Element

You're an attacker trying to break into a company. Would you rather:

- Spend days exploiting vulnerabilities and trying to bypass firewall defenses?
- Or just send a phishing email to the IT administrator - and get the access you need?

A computer network is like a fortress with towering stone walls and heavily armored gates. One way to conquer it is to breach through the gates, but another, a much simpler way - just ask the gatekeeper to open the door for you. In the cyber world, humans are often these naive "gatekeepers" - the weakest link in cyber security and those who help threat actors the most.



Why Humans Are Targeted

Humans are targeted because of the access they can provide - to websites, mailboxes, or databases. Some threat actors hunt for a specific access, while others are not so selective and just breach as many accounts as they can and decide how to use them later. Here are just a few examples of what threat actors hope for when trying to breach humans:

Attack Example	Next Step of Attackers
Breach Google account of the HR manager	Steal and sell the entire employee database
Trick a wealthy person into running malware	Hijack a web banking session from their PC

Breach the IT administrator's <u>VPN</u> account	Access the heart of a big corporate network
Trick a government worker into sharing secrets	Use the information to simplify the next attacks

What or who is the weakest link in cyber security?

Answer: **Humans**

What do attackers seek when targeting humans in a cyberattack?

Answer: **Access**

Task 3 Attacks on Humans

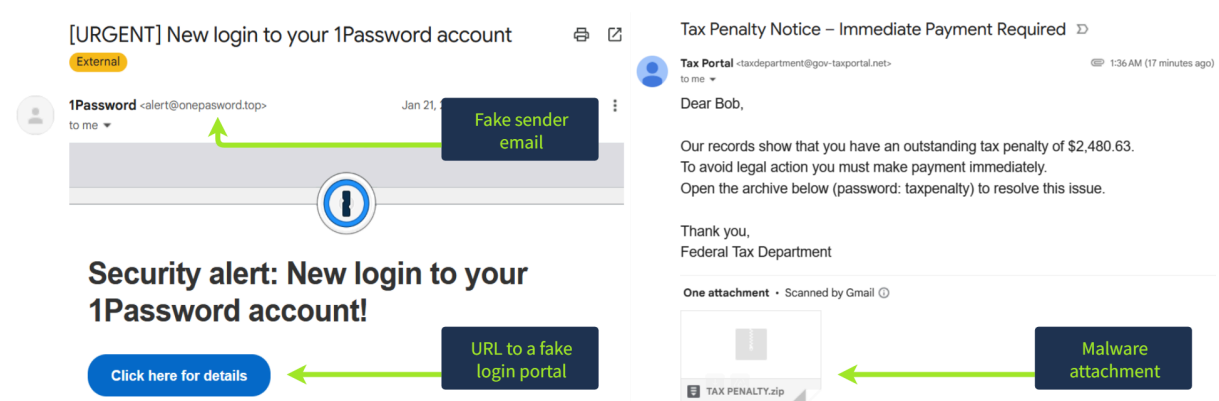
Attacks targeting humans share a common trait: they rely on manipulating the victim into helping the attacker, whether knowingly or not. This tactic is known as social engineering, and it works by exploiting human psychology rather than technical flaws. For the tactic to succeed, it is designed to be:

- **Trustworthy:** The attacker must appear legitimate so the victim trusts them
- **Emotional:** The attack must trigger feelings like urgency, fear, or curiosity

Phishing Attacks

You receive an email saying, "Your account has been compromised. Click here for details!" When you click on the link, it takes you to a fake login page that looks real, but sends your credentials to the attacker. That's phishing in action. Email phishing is the most common form of social engineering, with an estimated 3.4 billion:

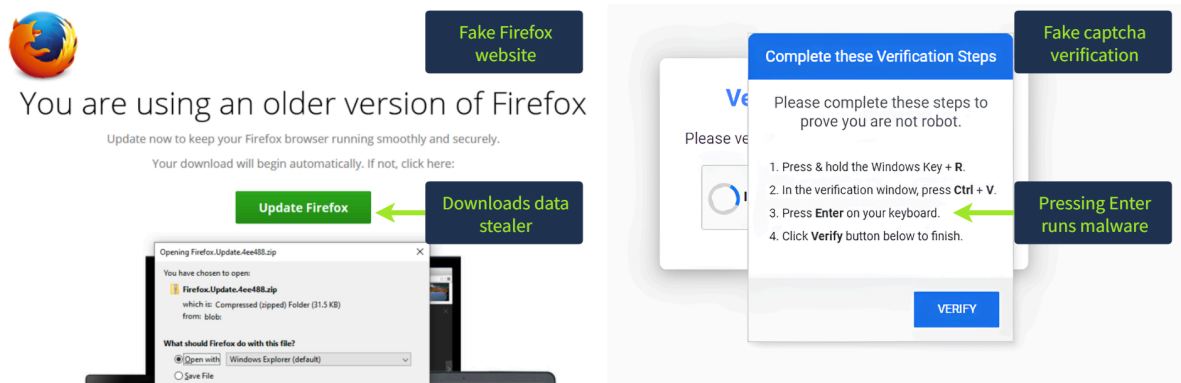
(<https://aag-it.com/the-latest-phishing-statistics/#:~:text=with%20an%20estimated%203.4%20billion%20spam%20emails%20sent%20every%20day>) malicious emails sent daily.



Malware Downloads

Ever searched for and installed the application on your PC? Well, you might have just installed

malware(<https://www.esentire.com/blog/fake-deepseek-site-infests-mac-users-with-atomic-stealer#:~:text=The%20infection%20process%20begins%20when%20the%20user%20is%20redirected>) on your computer. To make these attacks more successful, threat actors use innovative techniques like fake CAPTCHAs, malicious QR codes, and SEO poisoning.



Deepfakes

The rapid rise of AI-generated video or audio has become more effective in impersonating family members, colleagues, or corporate partners. In one case, a finance worker received a deepfake video call from someone appearing to be their boss and got tricked into wiring \$25 million for an "urgent business deal".

Impersonation

Even without deepfakes, the attackers are quite successful in pretending to be someone else (impersonating someone). Many recent ransomware attacks started with a simple phone call from attackers impersonating a corporate IT department and asking victims to take over their accounts for a quick "system repair".

Other Attacks

This task covered some popular social engineering methods, but there are many more! USB drop campaigns, physical attacks, insider threats, and even fake job offers - all of them are a constant risk to the employees, and you as a SOC analyst should be ready to respond!

What is the name of an attack tactic that manipulates human psychology?

Answer: **Social Engineering**

Which social engineering method is about pretending to be someone else?

Answer: **Impersonation**

Task 4 Defending Humans

Defending against threats involves two key tasks: Mitigation and Detection. Mitigation aims to prevent or reduce the chance and impact of attacks, for example by training employees or deploying a good anti-phishing solution. However, no matter how good mitigation measures are, one day they are bypassed. That's where your SOC skills are vital to detect and investigate advanced attacks that slip through:



Defending Humans

As a SOC analyst, your task is to detect and investigate attacks, and you'll have the whole SOC Level 1 path to learn it. However, you'll soon be tired of analyzing all the never-ending attacks and might think about how to automatically prevent common threats. This is why knowing key mitigation measures is essential. If your mitigation ideas are approved by IT and top management, you'll ease the SOC routine and make your company more secure! Here are a few examples of how to protect employees:

Mitigation	Description
Anti-phishing solution	<u>SOC</u> routine becomes easier with a tool that blocks <u>phishing</u> emails before the users even notice
Antivirus / <u>EDR</u> solution	A reliable antivirus on all corporate hosts is a great measure to prevent humans from running malware
"Trust but verify" principle	Instruct your employees how to detect deepfakes and verify suspicious requests from "CEO" or "IT"
Security awareness training	Teach your employees how to detect <u>phishing</u> and reinforce training through <u>phishing</u> simulations

Which process is aimed at preventing or reducing the chance of an attack?

Answer: **Mitigation**

Which mitigation measure is about training employees in cyber security?

Answer: **Security Awareness Training**

Task 5 Practice

Every organization faces constant attacks targeting its employees. However, the role of the SOC in responding to these attacks can vary. In some teams, analysts just monitor alerts. In others, they are deeply involved in the company's processes. Analysts may:

- Keep tight connections with the other teams, like IT or HR
- Propose security improvements and run company-wide trainings
- Or even answer hotline calls from employees suspecting the attack

Practice

For this lab, imagine yourself as a SOC analyst at TryHackMe. Open the security dashboard by clicking the **View Site** button, protect your coworkers at **Employees at Risk**, and make TryHackMe more secure at **Security Policy** tab. Once completed, claim the flags and answer the task questions!

New Chat Message from Lucas Martinez

Hey, I am a new software engineer. I urgently need 7-Zip archive software, but it doesn't launch. Can you review if it's because of your security tools?

Upon investigation, you see a "Setup.exe" downloaded from best-freeapps-2025.top, a new freeware hosting site. Lucas tried to launch it 6 times but was blocked by an antivirus. How would you respond to Lucas?

Your Verdict

Quarantine the Setup.exe.
Instruct Lucas to use the
official 7-Zip installer

Add the Setup.exe to the
antivirus exclusions. Ask
Lucas to try running it
again



New Chat Message from Lucas Martinez

Hey, I am a new software engineer. I urgently need 7-Zip archive software, but it doesn't launch. Can you review if it's because of your security tools?

Upon investigation, you see a "Setup.exe" downloaded from best-freeapps-2025.top, a new freeware hosting site. Lucas tried to launch it 6 times but was blocked by an antivirus. How would you respond to Lucas?

Correct Decision!



You investigated the quarantined file and understood that the Setup.exe was a data stealer. You've protected Lucas!

[Next Case](#)

New SIEM Alert: Suspicious Email Attachment

Title: Stripe Invoice #38291 - Payment Succeeded

From: noreply@stripe-payments.xyz

To: Mark Phillips, Finance Director

Content: This email confirms the \$23,650.00 payment from TryHackMe according to invoice #38291. For details, kindly see the attached Invoice.rar (password: 1111). If you have any questions, please get in touch with us at support@stripe.com.

Your Verdict

Allow the email and close the alert. This is a legitimate Stripe invoice

Block the email and start the analysis. This is an email phishing attempt

This email contains several red flags that indicate it is likely a phishing attempt:

1. **Suspicious Domain:** The email comes from noreply@stripe-payments.xyz. Stripe's legitimate domain is stripe.com, so this is a clear indication of a fraudulent domain.
2. **Unsolicited Attachment:** The email asks you to open a .rar file, which can often contain malicious software or viruses. Legitimate businesses, especially payment processors like Stripe, do not typically send sensitive information through attachments, especially with passwords.
3. **Password-protected Attachment:** The email includes a password (1111) for the attached file. This is another common tactic in phishing to bypass email filters and disguise malicious intent.
4. **Generic Language:** The email uses generic language ("if you have any questions, please get in touch with us"). This is often seen in phishing emails, where the attacker aims to create a sense of urgency or authority.

Given these factors, the correct action would be to block the email and start the analysis to investigate it as a potential phishing attempt.



New SIEM Alert: Suspicious Email Attachment

Title: Stripe Invoice #38291 - Payment Succeeded

From: noreply@stripe-payments.xyz

To: Mark Phillips, Finance Director

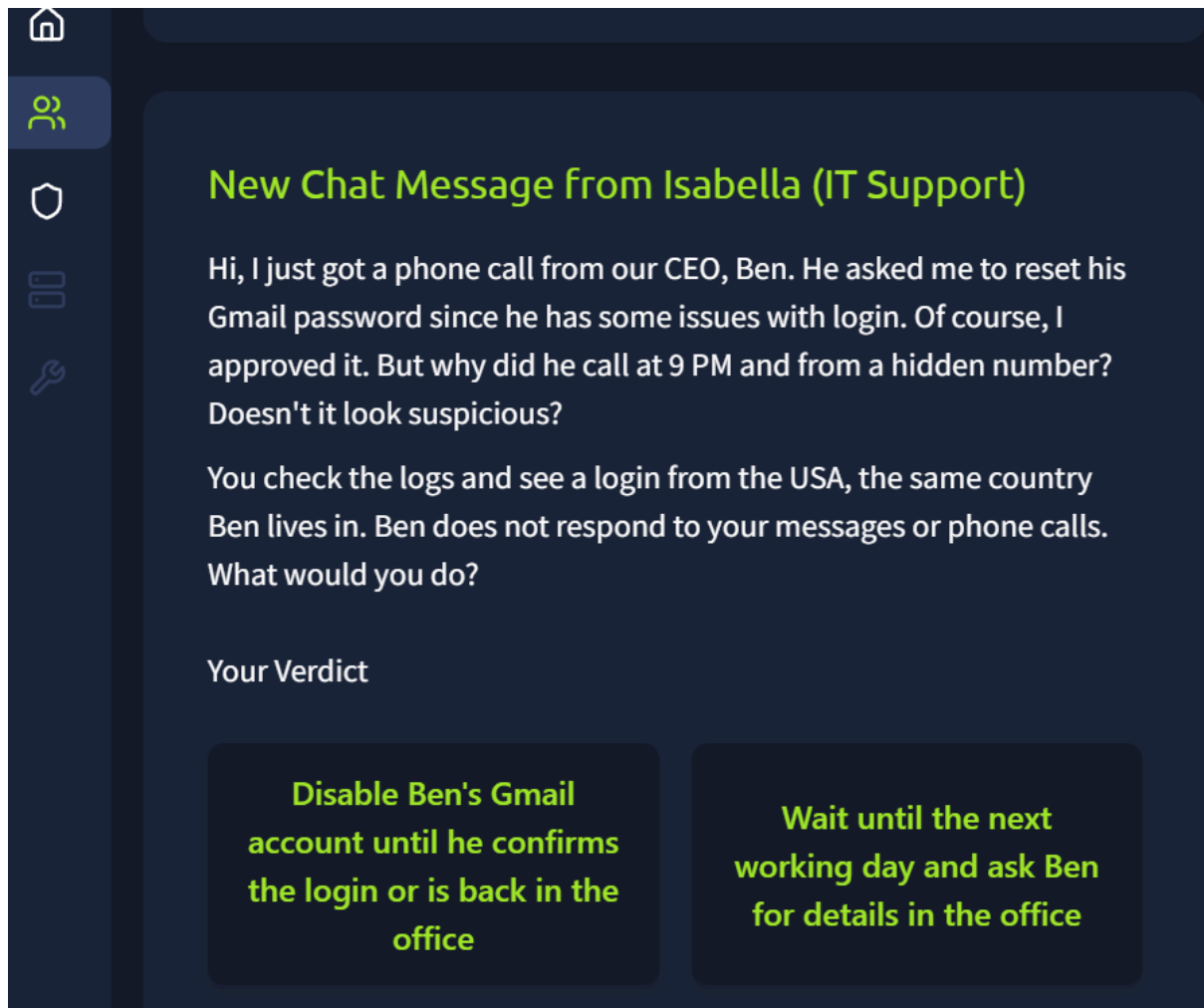
Content: This email confirms the \$23,650.00 payment from TryHackMe according to invoice #38291. For details, kindly see the attached Invoice.rar (password: 1111). If you have any questions, please get in touch with us at support@stripe.com.

Correct Decision!



You analyzed the email and confirmed your concerns: stripe-payments.xyz is a fake domain and the Invoice.rar contained a malicious DOCX document. You've protected Mark!

Next Case



This situation appears suspicious for a few reasons:

Hidden Number: A call from a hidden number is unusual, especially from the CEO, which can be a sign of an impersonation attempt.

Timing: A call at 9 PM is not typical for urgent requests.

Non-response: The lack of response from the CEO when trying to follow up further increases suspicion.

Given these red flags, the most prudent action is to disable Ben's Gmail account until he confirms the login or is back in the office. This helps prevent any unauthorized access while you verify the legitimacy of the request.



New Chat Message from Isabella (IT Support)

Hi, I just got a phone call from our CEO, Ben. He asked me to reset his Gmail password since he has some issues with login. Of course, I approved it. But why did he call at 9 PM and from a hidden number? Doesn't it look suspicious?

You check the logs and see a login from the USA, the same country Ben lives in. Ben does not respond to your messages or phone calls. What would you do?

Correct Decision!



When Ben returned, he did not confirm the phone call. It was a deepfake that you prevented before the attackers stole the CEO's emails!

[Next Case](#)



New SIEM Alert: Anomalous Login Location

User: Rose Lewis, HR Assistant

Login To: Microsoft 365

Login Location: London, UK

Typical Location: Oxford, UK

Visited URLs Before Login:

- <http://login.microsoft365-online.ru>
- <https://hroyhiqtspqgkp.info>
- <https://mail.tryhackme.thm>

Your Verdict

Close the alert. London is not far from Oxford, so the login location is expected

Disable the account of Rose Lewis until you are more confident in your verdict



New SIEM Alert: Anomalous Login Location

User: Rose Lewis, HR Assistant

Login To: Microsoft 365

Login Location: London, UK

Typical Location: Oxford, UK

Visited URLs Before Login:

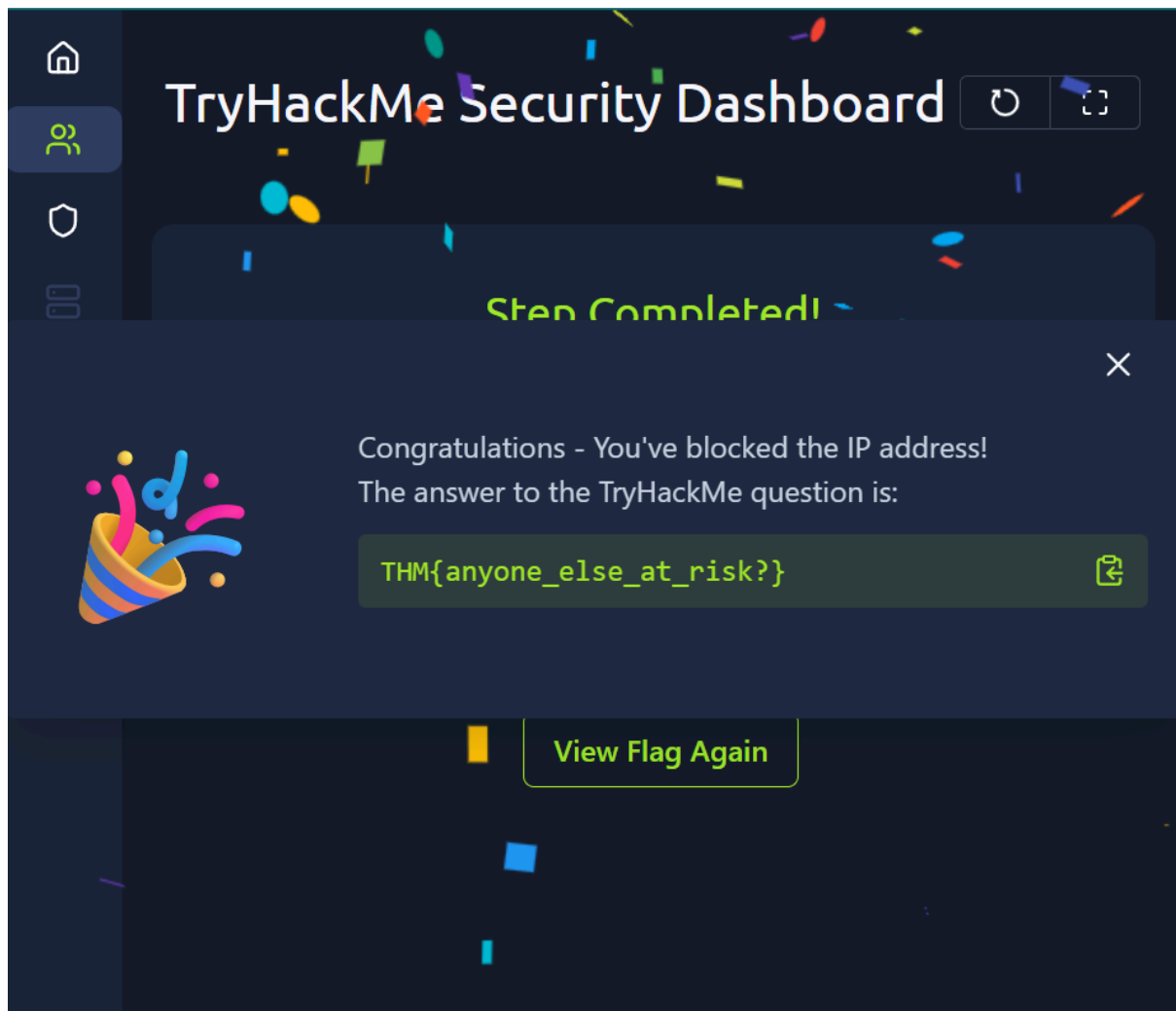
- [http://login\[.\]microsoft365-online\[.\]ru](http://login[.]microsoft365-online[.]ru)
- [https://hroyhiqtspqgkp\[.\]info](https://hroyhiqtspqgkp[.]info)
- [https://mail\[.\]tryhackme\[.\]thm](https://mail[.]tryhackme[.]thm)

Correct Decision!



You analyzed the last visited URLs before the login and confirmed that Rose fell victim to a fake login page. You've protected Rose!

Finish

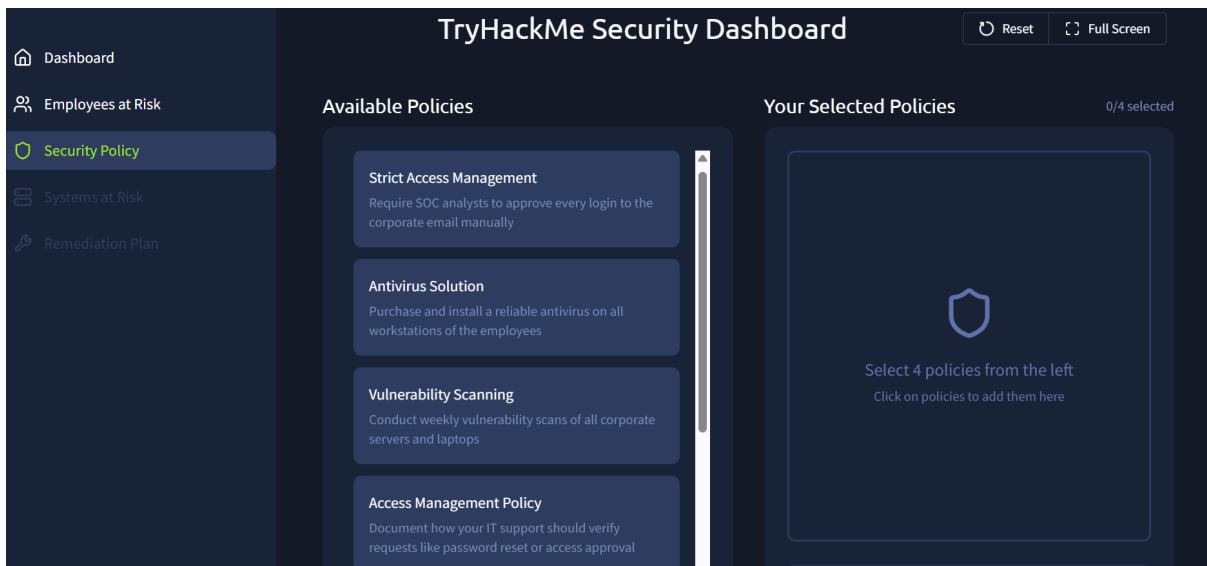
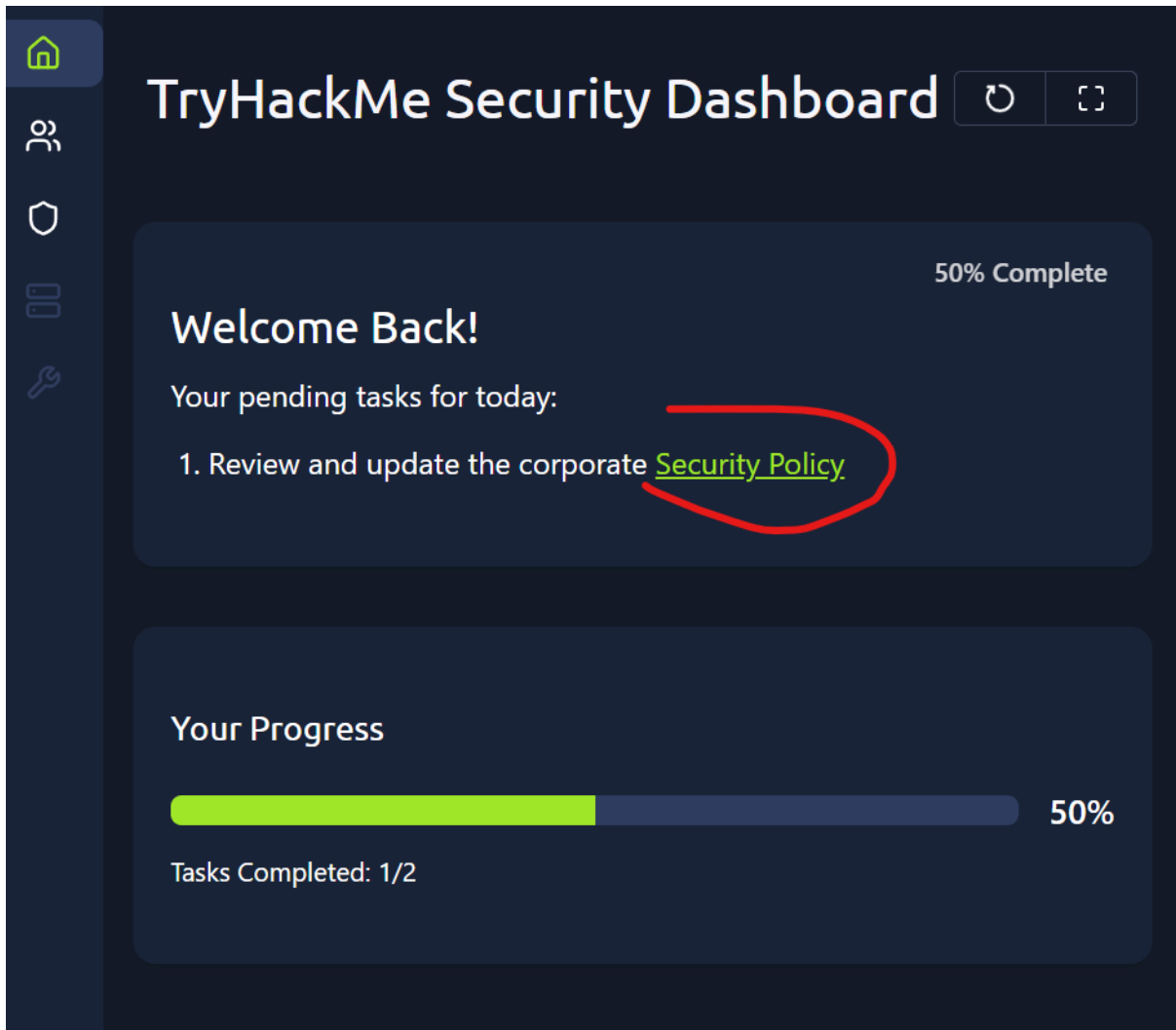


What flag did you receive after completing the "Employees at Risk" challenge?

Answer: `THM{anyone_else_at_risk?}`

What flag did you receive after completing the "Security Policy" challenge?

Answer: `THM{human_protection_expert!}`



Dashboard

Employees at Risk

Security Policy

Systems at Risk

Remediation Plan

Available Policies

Strict Access Management

Require SOC analysts to approve every login to the corporate email manually

Vulnerability Scanning

Conduct weekly vulnerability scans of all corporate servers and laptops

Internet Restrictions

Limit Internet access for all employees to only corporate resources

your Selected Policies

4/4 selected

1. Anti-Phishing Solution

Purchase and deploy a solution to detect and automatically block most phishing emails

2. Security Awareness Program

Setup quarterly trainings for all employees on how to detect and report modern phishing techniques

3. Antivirus Solution

Purchase and install a reliable antivirus on all workstations of the employees

4. Access Management Policy

Document how your IT support should verify requests like password reset or access approval

Submit Security Policy

Security Policy Feedback

You shared the prepared security policy with your colleagues and other departments and soon received the following feedback:

1. Anti-Phishing Solution

A bit pricy, but an excellent response since a lot of threats come through email!

2. Security Awareness Program

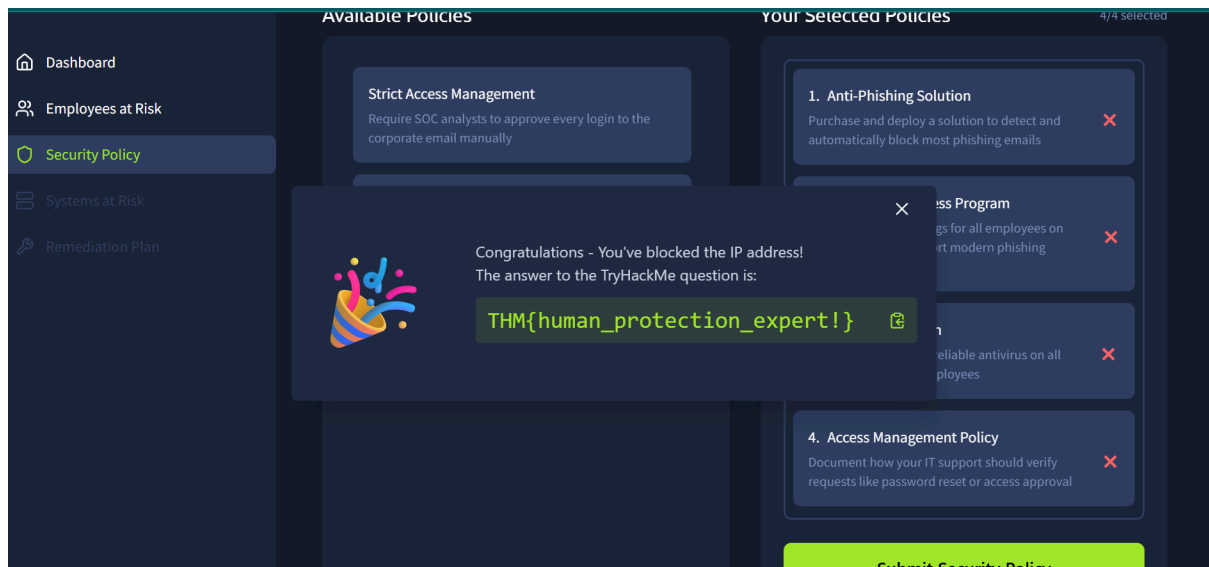
Not a bulletproof solution, but educating the employees is always a great idea!

3. Antivirus Solution

An expensive but strong response to malicious phishing attachments or malware downloads.

4. Access Management Policy

Approve



Task 6 Conclusion

In this room, you explored attacks on humans, the weakest element in cyber security. You have discovered how and why attackers target people and how you, as a SOC analyst, can detect and prevent it. But your journey shouldn't stop here. As threats evolve, staying informed about the latest attack trends is key to your success in the SOC. Here are a few great sites to follow:

- Krebs on Security - <https://krebsonsecurity.com>
- The Hacker News - <https://thehackernews.com>
- BleepingComputer - <https://www.bleepingcomputer.com>

The End.